

DNP3 — Distributed Network Protocol 3

Reading a substation SCADA conversation, frame by frame

- **Protocol:** DNP3
- **Transport:** TCP/20000 (also UDP/20000; some vendors use 19999 for a TLS variant)
- **Reference:** IEEE 1815-2012 (with DNP3 Secure Authentication v5)
- **Capture file:** `dnp3_substation.pcap`
- **Level:** Protocol analysis & defensive recognition — not an offensive tradecraft course. Intermediate (TCP/IP + basic Wireshark; new to ICS/OT)

Every frame number, field value, and CRC below was produced and verified with Wireshark/tshark and CISA's ICSNPP / Zeek. The capture is a curated teaching file — synthetic but protocol-valid.

1. What this module is

DNP3 is the workhorse SCADA protocol of the North American electric and water sectors. It carries the conversation between a **master** (the control-center software an operator watches) and one or more **outstations** (the RTUs and IEDs sitting in substations, pump houses, and tanks). The master polls outstations for measurements and status, outstations report changes as events, and the master sends control commands — open this breaker, start that pump.

DNP3 was designed in the early 1990s for slow, unreliable serial links, so it is compact, resilient, and layered in an unusual way (a data-link layer with its own CRCs, a tiny pseudo-transport layer, and a rich application layer of typed data objects). When utilities moved these links onto IP networks, DNP3 was simply wrapped in TCP on port 20000 — carrying along a 1990s security model: **no authentication, no encryption, and no authorization by default**. That gap is the throughline of this module.

You will analyze `dnp3_substation.pcap`, a curated 37-frame capture of a distribution substation being polled and controlled from a control center — followed by a rogue host on the same network issuing commands the outstation has no way to distinguish from the real master. Every frame number, field value, and CRC in this module was produced and verified with Wireshark/tshark and CISA's ICSNPP DNP3 parser.

2. Learning objectives

1. Given a DNP3 frame decoded in Wireshark, label the data-link, pseudo-transport, and application layers and state what each contributes to delivering one control message.
2. From a capture, classify each application function code (READ, RESPONSE, UNSOLICITED RESPONSE, SELECT, OPERATE, DIRECT OPERATE, COLD RESTART) and

distinguish a supervised SELECT→OPERATE sequence from a one-step DIRECT OPERATE, citing the function-code and application-control fields as evidence.

3. Given a RESPONSE frame, map its data objects (g1/g2 binary, g30/g32 analog, g20 counter, g12 CROB) to the physical substation points they represent and infer the outstation's state (e.g., breaker open vs. closed) from the field values.
4. [Assessed] Given an unseen capture that mixes traffic from more than one legitimate master with a single buried malicious frame, differentiate the legitimate traffic from the injected frame and justify the call by naming the fields that disagree (IP source vs. DNP3 link address, a missing SELECT, or an unsolicited response not originating from the outstation).
5. [Assessed] Given a proposed detection rule for DNP3 control abuse, critique its coverage, construct an attack variant that evades it (e.g., a spoofed UNSOLICITED RESPONSE carrying no control function code), and revise the rule so it catches the variant without alarming on legitimate masters.
6. For a substation that cannot be re-flashed to add DNP3-SA today, recommend and prioritize compensating controls (segmentation/allow-listing first, then DNP3-SA/TLS), explaining what each does and does not mitigate.
7. Using Zeek with the CISA ICSNPP DNP3 parser, produce dnp3_control.log and dnp3_objects.log from a capture and derive the single log line that best evidences an unauthorized control, naming the field that makes it detectable.

Scope & threat model — read this first

This module teaches you to **read** DNP3 and **recognize** its weaknesses on the wire. It does **not** teach you to attack a substation — it deliberately hands you the one thing a real operator-of-harm must earn first: a position on the wire between master and outstation.

The real ICS kill chain (MITRE ATT&CK for ICS): Initial Access → pivot into the OT network (Lateral Movement) → recon & address/asset enumeration (Discovery; Network Sniffing T0842) → **the injection you practice here** (Unauthorized Command Message, T0855) → optional impact/persistence (Manipulation of Control T0831; restart DoS T0814).

The frame-27 CROB trip is the **last ~5%**. The enumeration, the L2 adjacency to the RTU, and the access that precede it are the hard 95% — and are out of scope here. See 'What would make this real offense' below.

OT reality check — read this before frame 1

The topology here is deliberately collapsed: master, outstation, and 'rogue' host all sit on one routable subnet (10.20.0.0/24) so the injection is easy to see. Field distribution DNP3 rarely looks like this — it runs overwhelmingly over serial, leased line, licensed radio, or private cellular APNs; where carried on IP, the outstation terminates on a substation gateway reachable only from the control center's front-end processor, behind a firewall. A peer host able to open its own TCP session to the RTU (frame 27's premise) is therefore **already a segmentation failure**, not the normal starting condition.

Consequence is not symmetric, either. A feeder **trip (OPEN)** is the fail-safe, self-announcing, reversible direction. The genuinely dangerous act is an unsupervised **CLOSE** — onto a grounded line or working crew, into a fault, or out of synchronism — which real substations

gate with hot-line/clearance tags, sync-check (25) relays, reclose-blocking, and a local/remote (43) switch that removes the breaker from SCADA during maintenance. Treat 'opened a breaker' and 'closed a breaker' as different risk classes.

Lab-topology note: the flat subnet and (in the lab) Docker networks stand in for VLANs / zone firewalls; addresses are illustrative.

3. Where this protocol lives — industry & use cases

DNP3 is not a general-purpose IT protocol — it lives almost entirely inside critical infrastructure, which is exactly why its weaknesses matter. If you see DNP3 on a network, you are almost certainly looking at an operational-technology (OT) environment where packets move physical equipment.

Electric power (its heartland). Transmission and distribution utilities use DNP3 between control-center SCADA/EMS masters and substation RTUs, protective relays, and IEDs. It reports bus voltages, line currents, breaker and switch status, and carries trip/close commands. In North America, NERC CIP covers Bulk Electric System cyber systems — broadly transmission at 100 kV and above plus certain generation — so most transmission-substation DNP3 is in scope; ordinary distribution feeders like this one generally are not (they fall to state public-utility commissions, with narrow exceptions such as UFLS or a Remedial Action Scheme).

Water and wastewater. Municipal utilities use DNP3 to monitor tank levels, pump status, flow, and chlorine dosing across geographically spread lift stations and treatment plants — often over cellular or radio backhaul.

Oil, gas, and pipelines. Used for remote wellheads, compressor stations, and pipeline monitoring where long serial/radio distances favored DNP3's compact, robust framing.

Transportation & building infrastructure. Appears in rail signaling telemetry, tunnel and traffic systems, and large campus/utility plants.

Typical use cases

- Integrity poll: the master periodically asks an outstation for its full current state (a 'give me everything' Class 0/1/2/3 READ).
- Report-by-exception: outstations send UNSOLICITED RESPONSES the instant a monitored point changes, instead of waiting to be polled.
- Supervised control: an operator closes or trips a breaker using SELECT-then-OPERATE so the target is confirmed before the action fires.
- Time synchronization and file transfer for downstream devices and event logs.

4. Protocol anatomy

DNP3 is built on the IEC 60870-5 'Enhanced Performance Architecture,' whose canonical layers are physical, data link, and application — plus an added **pseudo-transport** sublayer (so DNP3 is often called a '3+1' stack). On an IP network the physical layer is just TCP/IP, so what you actually expand in Wireshark are three software layers inside each TCP segment: data link,

pseudo-transport, and application. Understanding the split makes the capture readable — and explains where security controls can (and cannot) be added.

Data Link Layer

Starts with the sync bytes 0x05 0x64, then a length octet, a control octet (direction/primary bits + a link function code), and 16-bit destination and source link addresses (little-endian). A 2-byte CRC follows the header and every 16-byte data block. In our capture the master is link address 100 and the outstation is 10.

0x0564 · len · ctrl · dest(2) · src(2) · CRC — then data blocks each +CRC

Pseudo-Transport Layer

A single octet (FIR/FIN bits + a 6-bit sequence number) that lets long application messages be split across multiple link frames and reassembled. Small messages set both FIR and FIN.

1 octet: FIR | FIN | 6-bit sequence

Application Layer

An application-control octet (FIR/FIN/CON/UNS + 4-bit sequence), a one-byte function code, and — in responses only — a two-byte Internal Indications (IIN) field, followed by typed data objects. Objects are addressed by Group/Variation (e.g., g1v2 = binary input with flags, g30v1 = 32-bit analog input, g12v1 = CROB control block).

app-ctrl · function-code · [IIN(2) if response] · objects...

Function / packet types you will see

Code	Name	Meaning
0x01	READ	Master asks the outstation for data (often a class poll).
0x02	WRITE	Master writes values/config to the outstation.
0x03	SELECT	Arm a control point — must be confirmed by an OPERATE.
0x04	OPERATE	Execute the control previously armed by SELECT.
0x05	DIRECT OPERATE	Execute a control in one step (no SELECT).
0x0D	COLD RESTART	Command the outstation to fully restart.
0x81	RESPONSE	Outstation reply to a request (carries IIN + objects).
0x82	UNSOLICITED RESPONSE	Outstation-initiated event

Code	Name	Meaning
		report (no poll).

5. The capture at a glance

A distribution substation (outstation, DNP3 address 10, at 10.20.0.20) is polled and controlled by the control-center SCADA master (address 100, at 10.20.0.5). The session shows a routine poll/response rhythm, an event report, and a supervised breaker close. Then a rogue host (10.20.0.66) opens its own TCP session to the outstation and — spoofing the master’s link address — issues control and restart commands the outstation obeys.

Host / role	Address	Notes
Master / Control center	10.20.0.5	DNP3 link address 100 — the SCADA/EMS master an operator watches
Outstation / Substation RTU	10.20.0.20:20000	DNP3 link address 10 — RTU/IED controlling a feeder breaker
Rogue host	10.20.0.66	Attacker with network reachability to the outstation; spoofs the master address

37 frames · 2 TCP streams · TCP/20000 · master ↔ outstation poll/control + rogue-host injection

6. Frame-by-frame walkthrough

Open the matching .pcap in Wireshark and follow along; the frame numbers line up exactly.

Frame 1 — 52100 → 20000 [SYN]

t=0.000s · 10.20.0.5 → 10.20.0.20 · TCP

The master opens the TCP connection to the outstation on DNP3’s port 20000. DNP3-over-TCP rides an ordinary 3-way handshake.

Field	Value
Dst port	20000 (DNP3)
Flags	SYN

Why it matters. Port 20000 is the fingerprint of DNP3 on a network. Seeing it between an IT-looking host and an OT device is itself worth noting.

Wireshark filter: tcp.port==20000 && tcp.flags.syn==1

Frame 4 — Read, Class 0123 (integrity poll)

t=0.002s · 10.20.0.5 → 10.20.0.20 · DNP3

The master's integrity poll: 'send me all your Class 1, 2, 3 event data and your Class 0 static data.' This is how a master gets a complete current picture of the outstation.

Field	Value
App function	READ (0x01)
Objects	g60 v2,v3,v4,v1 (Class 1/2/3/0) qualifier 0x06 = all
Link dst-src	10 ← 100
Data-link CRC	valid

Why it matters. Group 60 is 'class data' — a shorthand for 'whatever points you have assigned to these classes.' Qualifier 0x06 means 'all objects, no range.' One tiny request pulls the outstation's entire state.

Wireshark filter: `dnp3.al.func==1`

Frame 6 — Response — binary + analog inputs

`t=0.004s · 10.20.0.20 → 10.20.0.5 · DNP3`

The outstation answers with its current data: four binary inputs (breaker and switch status) and three 32-bit analog inputs (bus voltage and per-phase line currents).

Field	Value
App function	RESPONSE (0x81)
IIN	0x0000 (no flags — healthy)
glv2	4 binary inputs — pts 0,1 = 1 (closed); pts 2,3 = 0
g30v1	3 analog inputs = 13245, 452, 6001

Why it matters. This single response is a slice of the substation's state in bytes: breaker CLOSED, disconnect CLOSED, ground switch OPEN, plus live analog telemetry. The two-byte IIN is the outstation's health flag word; 0x0000 means 'all normal.' Scale caveat: this is a deliberately tiny teaching slice — a real feeder RTU carries hundreds to thousands of points, not seven.

NOTE. Everything here is in cleartext. Anyone capturing this traffic reads the live state of the substation — reconnaissance requires no decryption.

Wireshark filter: `dnp3.al.func==129`

Frame 8 — Read, Class 0 (static poll)

`t=2.006s · 10.20.0.5 → 10.20.0.20 · DNP3`

Two seconds later the master runs a lighter Class 0 poll — just the current static values, no events.

Field	Value
App function	READ (0x01)
Objects	g60 v1 (Class 0) qualifier 0x06

Why it matters. Masters mix heavy integrity polls with frequent light Class-0 polls to keep the display fresh without flooding slow links. Spotting the polling rhythm helps you baseline ‘normal’ for an outstation.

Wireshark filter: `dnp3.al.func==1`

Frame 10 — Response — inputs + counter

`t=2.007s · 10.20.0.20 → 10.20.0.5 · DNP3`

The outstation returns updated binary and analog values plus a 32-bit counter (e.g., an accumulated energy/pulse count of 148213).

Field	Value
App function	RESPONSE (0x81)
g1v2	4 binary inputs
g30v1	3 analog inputs = 13240, 455, 6000
g20v1	counter = 148213

Why it matters. Counters (group 20) accumulate — think kWh or pulse totals. Analog values drift slightly between polls (452–455), which is exactly what live instrumentation looks like.

Wireshark filter: `dnp3.al.func==129`

Frame 12 — Unsolicited Response — binary input event

`t=5.509s · 10.20.0.20 → 10.20.0.5 · DNP3`

Without being polled, the outstation reports a change: a breaker auxiliary contact opened (binary input event, point 0 → 0). This is DNP3 ‘report-by-exception.’

Field	Value
App function	UNSOLICITED RESPONSE (0x82)
App control	UNS + CON set (confirmation requested)
IIN	0x0200 — Class 1 data available
g2v1	binary input event, point 0 = 0

Why it matters. Unsolicited responses are how operators learn about a trip within milliseconds instead of at the next poll. The UNS bit in the application control octet is what distinguishes an event report from a polled response.

NOTE. Because responses carry no authentication, a spoofed unsolicited response could feed an operator false status (MITRE ATT&CK for ICS T0856, Spoof Reporting Message). Nothing in the frame proves it came from the real outstation.

Wireshark filter: `dnp3.al.func==130`

Frame 14 — Confirm

`t=5.510s · 10.20.0.5 → 10.20.0.20 · DNP3`

The master acknowledges the event at the application layer with a CONFIRM, so the outstation knows the event was received and can clear it from its buffer.

Field	Value
App function	CONFIRM (0x00)
App control	UNS set, matching sequence

Why it matters. DNP3 has confirmations at both the link and application layers. Application confirms make report-by-exception reliable over lossy links — events aren't dropped silently.

Wireshark filter: `dnp3.al.func==0`

Frame 16 — SELECT — CROB close breaker

`t=8.012s · 10.20.0.5 → 10.20.0.20 · DNP3`

The operator initiates a supervised control: SELECT the feeder breaker's Control Relay Output Block (CROB) with a Close / Pulse-On command. SELECT arms but does not fire.

Field	Value
App function	SELECT (0x03)
Object	g12v1 CROB, point 0
Control code	0x41 — Close, Pulse On
On-time	1000 ms

Why it matters. The CROB is the single most security-relevant object in DNP3: it is a command that moves physical equipment. Group 12, variation 1, point index = which relay/breaker. (A 1000 ms pulse is on the long side for a trip/close coil — the breaker's own 52a/52b auxiliary contacts interrupt the coil within a few cycles, and utilities typically set output pulses well under a second.)

CAUTION. This is a legitimate control from the real master — but the outstation accepts it purely on the basis of link/source addressing, which is trivially spoofable. Hold this thought for frame 27.

Wireshark filter: `dnp3.al.func==3`

Frame 18 — Response — select echo (Success)

t=8.014s · 10.20.0.20 → 10.20.0.5 · DNP3

The outstation echoes the CROB back with a status of Success, confirming it is armed and ready to operate the selected point.

Field	Value
App function	RESPONSE (0x81)
Echoed CROB	Close, Pulse On, point 0
Status	Success (0)

Why it matters. The echo lets the master verify the outstation understood exactly the point and action requested before it commits. A mismatch here would abort the control.

Wireshark filter: dnp3.al.func==129

Frame 20 — OPERATE — execute the close

t=8.015s · 10.20.0.5 → 10.20.0.20 · DNP3

The master sends OPERATE for the same CROB. This is the command that actually closes the breaker.

Field	Value
App function	OPERATE (0x04)
Object	g12v1 CROB, point 0, Close/Pulse On

Why it matters. SELECT-before-OPERATE is DNP3's safety interlock: two matching messages are required to move equipment, reducing the chance a single corrupted or stray frame throws a breaker. Note this is a **safety and robustness** interlock, not authentication — a forger who can send a DIRECT OPERATE can just as easily send a SELECT and then a matching OPERATE.

Wireshark filter: dnp3.al.func==4

Frame 22 — Response — operate echo (Success)

t=8.017s · 10.20.0.20 → 10.20.0.5 · DNP3

The outstation confirms the operation succeeded — the breaker is now closed. The supervised control sequence is complete.

Field	Value
App function	RESPONSE (0x81)
Status	Success (0)

Why it matters. Frames 16–22 are the full, correct control lifecycle: SELECT → echo → OPERATE → echo. Memorize this shape; deviations from it (an OPERATE with no preceding SELECT, or a control from an unexpected source) are red flags.

Wireshark filter: dnp3.al.func==129

Frame 27 — Direct Operate — CROB TRIP (rogue host) ANOMALY

t=12.021s · 10.20.0.66 → 10.20.0.20 · DNP3

A different host (10.20.0.66) — not the master — opens its own session and issues a DIRECT OPERATE that TRIPS (opens) the breaker in one step, with no SELECT and no authorization. It spoofs the master's DNP3 link address (100).

Field	Value
Source IP	10.20.0.66 (NOT the master 10.20.0.5)
App function	DIRECT OPERATE (0x05)
Object	g12v1 CROB — Trip, Pulse On
Spoofed link src	100 (the master's address)

Why it matters. This is the module's centerpiece. Nothing in DNP3 lets the outstation tell this apart from a real command. The only 'identity' is a 16-bit link address the attacker simply wrote into the frame.

CRITICAL. Unauthorized command injection — MITRE ATT&CK for ICS T0855. The teaching point is narrow and real: the outstation performs no origin check, so an unauthenticated frame is obeyed. Resist over-claiming the analogies — the 2007 Aurora test destroyed a generator by re-CLOSING it out of synchronism (a mechanical-torque attack that sync-check (25) relays defend against), not by a feeder trip; and Ukraine 2015 was hands-on-keyboard operation of the utility's own HMIs via stolen credentials, with Industroyer using IEC-101/104, IEC 61850, and OPC — not DNP3. Fix: DNP3-SA, source allow-listing, segmentation.

Wireshark filter: dnp3.al.func==5

Frame 29 — Response — Success (breaker tripped) ANOMALY

t=12.022s · 10.20.0.20 → 10.20.0.66 · DNP3

The outstation obeys the rogue command and returns Success. The breaker is now open — an unplanned outage — caused by a host that never authenticated.

Field	Value
App function	RESPONSE (0x81)
Status	Success (0)
Reply to	10.20.0.66

Why it matters. The outstation politely reports success to the attacker. In CISA's ICSNPP dnp3_control.log this appears as a DIRECT_OPERATE / Trip / Success line from source 10.20.0.66 — a detection you can build on.

CRITICAL. Detection nuance: the obvious rule — alarm when a control's source IP isn't the master — fires here only because the attacker kept his real IP (10.20.0.66) while forging just the

DNP3 link address. A smarter attacker spoofs the master's IP or hijacks its TCP session and evades it. See 'Detection under adversarial and operational reality' below for the invariant-based rule that survives.

Wireshark filter: `dnp3.al.func==129 && ip.dst==10.20.0.66`

Frame 31 — Cold Restart (rogue host) ANOMALY

`t=13.524s · 10.20.0.66 → 10.20.0.20 · DNP3`

The rogue host follows up with a COLD RESTART — commanding the outstation to fully reboot, dropping its monitoring and control of the substation while it restarts.

Field	Value
Source IP	10.20.0.66
App function	COLD RESTART (0x0D)

Why it matters. A restart is a denial-of-availability weapon in OT: while the RTU reboots, operators are blind and cannot control the site. No credentials were needed.

CRITICAL. Denial of Service against a control device — MITRE ATT&CK for ICS T0814. Function-code filtering at an OT firewall (block COLD RESTART from anything but the master) and DNP3-SA both mitigate this.

Wireshark filter: `dnp3.al.func==13`

Frame 33 — Response — Device Restart (IIN set) ANOMALY

`t=13.526s · 10.20.0.20 → 10.20.0.66 · DNP3`

The outstation acknowledges the restart. Its Internal Indications now show the Device Restart bit set, and it returns a time-delay object indicating how long it will be unavailable.

Field	Value
App function	RESPONSE (0x81)
IIN	0x8000 — Device Restart set
g52v2	time delay = 30000 ms

Why it matters. IIN bit 1.7 (Device Restart) is how an outstation tells a master 'I just rebooted — re-initialize me.' Seeing it unexpectedly, or triggered from a non-master source, is a strong incident signal.

CAUTION. The restart IIN flag is a free tripwire: a master (or monitoring tool) that sees an unexpected Device Restart should investigate why the outstation rebooted.

Wireshark filter: `dnp3.al.iin.rst==1`

7. Security risks & controls

D1 • No authentication on control commands

Severity: CRITICAL, frames 16, 20, 27

- **Risk.** Base DNP3 accepts control commands (SELECT/OPERATE/DIRECT OPERATE) with no proof of identity. The outstation trusts a 16-bit link address that any host on-path can spoof, so a valid-looking TRIP or CLOSE can come from anywhere with network reachability (frame 27).
- **Real-world.** The 2015 Ukraine grid attack opened breakers by operating the utility's own HMIs with stolen credentials; the 2007 INL Aurora test destroyed a generator by re-closing it out of synchronism (defended by sync-check relays). Both illustrate that command integrity — not data secrecy — is the crown jewel in OT, though neither was itself a DNP3 exploit.
- **Technique.** MITRE ATT&CK for ICS T0855 (Unauthorized Command Message)
- **Control.** Deploy DNP3 Secure Authentication (SAv5, IEEE 1815-2012): a challenge-response MAC on critical function codes proves a command came from a keyed master and was not altered. Layer on strict source allow-listing, IEC 62443 zones/conduits, and NERC CIP access controls. Note SAv5 provides authenticity and integrity, not confidentiality.

D2 • No encryption — full cleartext

Severity: HIGH, frames 6, 10, 27

- **Risk.** Every value, command, and address travels in the clear. An attacker who can capture traffic learns the substation's live state, point map, and control structure with zero cryptographic effort (frames 6 and 10 are a ready-made reconnaissance feed).
- **Real-world.** Cleartext OT telemetry is the reconnaissance foundation that precedes targeted ICS attacks; mapping the process is a documented step in intrusions like Industroyer.
- **Technique.** MITRE ATT&CK for ICS T0842 (Network Sniffing)
- **Control.** Tunnel DNP3 over TLS or an IPsec/VPN conduit between substation and control center; segment the OT network so capture points are limited; monitor with a protocol-aware sensor. Encryption complements — does not replace — DNP3-SA.

D3 • Source spoofing / command injection

Severity: CRITICAL, frames 27, 29

- **Risk.** An unsolicited DIRECT OPERATE from an unexpected IP, spoofing the master's link address, is executed and acknowledged (frames 27–29). There is no SELECT interlock on DIRECT OPERATE and no source verification.
- **Real-world.** Command injection is possible only because the outstation cannot verify the sender; years of ICS-CERT advisories on internet-exposed and weakly-segmented DNP3 endpoints show how often that reachability exists in practice.
- **Technique.** MITRE ATT&CK for ICS T0855 / T0856 (Spoof Reporting Message)

- **Control.** Lead with the controls you can deploy without re-flashing: an OT firewall/data diode that lets only the sanctioned front-end processor reach TCP/20000, IEC 62443 zones/conduits, and a Zeek+ICSNPP sensor keyed on the invariant {link address $\leftrightarrow$ expected source $\leftrightarrow$ known-master set $\leftrightarrow$ SELECT-before-OPERATE} rather than a single source IP. DNP3-SA is the durable upgrade that authenticates the command's origin. Disabling DIRECT OPERATE only lowers the odds of an accidental single-frame actuation — it does not stop an attacker, who can forge SELECT then OPERATE just as easily.

D4 • Availability attacks via control functions

Severity: HIGH, frames 31, 33

- **Risk.** COLD RESTART (and its warm variant) will reboot an outstation on command, blinding operators to the site during recovery (frames 31–33). Combined with spoofing, it is a remote denial-of-control.
- **Real-world.** Loss of view/loss of control is a recurring objective in grid intrusions; the 2015 Ukraine attackers also bricked serial-to-Ethernet converters to prolong the outage.
- **Technique.** MITRE ATT&CK for ICS T0814 (Denial of Service)
- **Control.** Block administrative function codes (COLD/WARM RESTART) from all sources except the master at an OT firewall; require DNP3-SA for critical functions; monitor for unexpected Device Restart IIN flags.

D5 • Protocol-implementation fragility (fuzzing)

Severity: HIGH

- **Risk.** Many DNP3 stacks historically mishandled malformed frames, allowing a single crafted packet to crash or hang a master or outstation — a denial of service against the monitoring path itself. This is an implementation problem, separate from the design gaps above.
- **Real-world.** Project Robus (Adam Crain & Chris Sistrunk) reported on the order of 28 flaws and roughly 16 ICS-CERT advisories across vendor DNP3 stacks as of early 2014 (umbrella advisory ICSA-13-291-01B, improper input validation); the effort continued through 2016 to ~30+ advisories in total.
- **Technique.** MITRE ATT&CK for ICS T0814 (Denial of Service)
- **Control.** Patch to fuzz-tested stack versions; front devices with a protocol-aware firewall/IDS that drops malformed DNP3; include robustness/fuzz testing in ICS procurement (per NIST SP 800-82r3 guidance).

Detection under adversarial and operational reality

The module's headline rule — *alarm on any control whose source is not the sanctioned master IP* — survives this capture only by luck. It keys on `source_h`, an IP field in `dnp3_control.log`. But the attacker in frame 27 forged only the 16-bit DNP3 **link** address (writing the master's 100) and left his real IP (10.20.0.66) untouched — so `source_h` still reads 10.20.0.66 and the alert happens to fire.

Note what the sensor cannot see: the forged link address appears in **no** default ICSNPP log (dnp3.log carries fc_request/fc_reply/iin; dnp3_control.log carries only source/destination IPs). To key on the field the attacker actually forged, you must first extend the parser to emit it.

Worse, a competent adversary spoofs the master's **IP** — free from an on-segment position, or by hijacking the master's still-open TCP session to :20000 — yielding source_h = the master and **no** alert. The rule is also base-rate naive: real outstations answer to a **set** of legitimate masters (primary + backup control centers, multiple front-end processors, DMS/OMS, engineering laptops during commissioning and relay testing), so a single-IP rule either floods the SOC or is brittle.

Durable detection keys on an **invariant** the attacker cannot cheaply satisfy — bind {DNP3 link address → expected source IP/TCP session → known-master allow-set → SELECT-before-OPERATE}. Alarm on OPERATE with no matching in-window SELECT, brand-new sessions to :20000, or off-baseline function codes/timing — correlated in a SIEM with maintenance-window suppression and asset-inventory enrichment, not a lone packet rule.

When you encrypt, you blind your network sensor

The confidentiality controls (DNP3 D2; MQTT M1/M2) close the exposure gap but move the detection boundary. Once transport is encrypted — DNP3 over TLS/VPN, MQTT on 8883 — the ICSNPP/Zeek sensor goes **dark**: Zeek emits no mqtt_*.log on 8883 (only ssl.log), and a DNP3-in-TLS tunnel is opaque to ICSNPP. Detection must then move to broker auth logs, RTU/endpoint syslog, flow/JA3 metadata, or a controlled decryption/inspection point. Draw the line precisely: DNP3 Secure Authentication (SAv5) is a MAC — authenticity and integrity only — so it does **not** blind ICSNPP; only the transport-encryption controls do.

Sensor placement. Detection only works if the tap sees the traffic. Site the sensor on a mirror/SPAN or TAP at the OT/DMZ conduit the control-center master traverses. An attacker on the substation LAN injecting into the **local** RTU never crosses a control-center SPAN, and serial-tail DNP3 (RS-232/485 into the RTU) is invisible to any network sensor.

What would make this real offense (out of scope in this kit)

A fuller offensive track — deliberately **out of scope** in this analysis-and-recognition kit — would add:

- **Asset/address enumeration** — derive the outstation and master link addresses, point map, and class assignments from a capture or scan, instead of being handed 10/100.
- **L2 positioning** — ARP-spoof the master→outstation path to get on-path; this kit assumes that adjacency already exists.
- **TCP-session hijack** — ride the master's existing session instead of opening a fresh, easily-flagged socket.
- **Defeat SELECT-before-OPERATE** — capture and replay a valid SELECT, or win the operate race, rather than side-stepping it with DIRECT OPERATE.
- **DNP3-SA attacks** — aggressive-mode replay, session-key recovery, and downgrade/strip to force base DNP3.

- **Real malformed-frame fuzzing** — an actual fuzz harness that crashes a stack (finding D5 cites Project Robus but ships no fuzzer).

8. Hands-on lab

The Docker lab ships a small Python DNP3 outstation and master so you can generate your own traffic, plus tcpdump to replay this capture and Zeek + the CISA ICSNPP DNP3 parser to turn packets into readable logs. Start with the provided pcap in Wireshark, then reproduce it live.

Exercise 1. Find the control lifecycle

1. Open dnp3_substation.pcap in Wireshark.
2. Apply the display filter dnp3.al.func in {3,4,5} to isolate every control.
3. Identify the legitimate SELECT–OPERATE pair and the rogue DIRECT OPERATE.

Question. How many control messages are there, and which one lacks a SELECT — and why does that matter?

Answer. Three controls: SELECT (frame 16) and OPERATE (frame 20) from the master, and a DIRECT OPERATE (frame 27) from 10.20.0.66. The DIRECT OPERATE has no SELECT interlock and comes from a non-master IP — it is the injected TRIP that opens the breaker.

Exercise 2. Spot the impostor by address

1. Filter dnp3 and add columns for ip.src and dnp3.src (DNP3 link source).
2. Compare the IP source and the DNP3 link source for every control frame.

Question. What is inconsistent about frame 27, and which field did the attacker forge?

Answer. Frame 27's IP source is 10.20.0.66 but its DNP3 link source is 100 — the master's address. The attacker forged the link source to impersonate the master. Base DNP3 has no way to reject this.

Exercise 3. Turn packets into detections with ICSNPP

1. In the lab container run: `zeek -C -r /pcaps/dnp3_substation.pcap icsnpp-dnp3`
2. Open dnp3_control.log and dnp3_objects.log.

Question. Which single log line is your best alert for the attack, and what field makes it detectable?

Answer. The dnp3_control.log line 'DIRECT_OPERATE ... Trip ... Success' whose source_h is 10.20.0.66. But note that works here only because the attacker kept his real IP while forging the DNP3 link address; a smarter attacker who also spoofs the master's IP (or hijacks its TCP session) defeats a source-IP rule. The durable detection keys on an invariant — a control with no preceding SELECT, from an unexpected session, or off the master's baseline cadence (see 'Detection under adversarial and operational reality').

Exercise 4. Design the control

1. Re-read security findings D1 and D3.
2. Given a substation you cannot re-flash to add DNP3-SA tomorrow, list compensating controls you can deploy this week.

Question. Name three compensating controls that reduce the frame-27 risk without changing the outstation firmware.

Answer. (1) OT firewall rule allowing TCP/20000 to the outstation only from the master IP; (2) network segmentation / a data diode isolating the control LAN; (3) a Zeek+ICSNPP sensor alarming on controls from non-master sources. DNP3-SA is the durable fix once the device supports it.

9. O*NET personas & career pathways

This module is framed around real O*NET occupational personas — the subject-matter voices that shaped it and the people whose work it maps to (see the split below: skills you practice vs. who this protects).

51-8012.00 — Power Distributors and Dispatchers (*Control-room career target*)

“I sit at the SCADA/EMS master. When I close a breaker, frames 16–22 are literally my mouse click leaving the building.”

O*NET tasks: ‘Control, monitor, or operate equipment that regulates or distributes electricity ... using data obtained from instruments or computers’ and ‘Prepare switching orders.’ DNP3 is the wire under those tasks. Tools list includes SCADA and EMS/OMS software.

49-2095.00 — Electrical & Electronics Repairers — Powerhouse, Substation, and Relay (*Device-level career target (Bright Outlook)*)

“I build, test, and repair the substation relay and control systems that are the outstation in this capture.”

O*NET tasks: ‘Construct, test, maintain, and repair substation relay and control systems’ and ‘Inspect and test equipment and circuits.’ This is the hands-on OT role that lives closest to the DNP3 outstation.

15-1212.00 — Information Security Analysts (*SME voice / IT-OT bridge (Bright Outlook)*)

“I baseline the poll rhythm, then write the detection that fires when a control comes from the wrong source.”

One of the few O*NET IT-security occupations whose tool list explicitly names SCADA software alongside Wireshark and IDS/IPS — the natural author of the detections in this module.

17-2071.00 — Electrical Engineers (*Design authority (Bright Outlook)*)

“I specify the RTUs and the point map, and increasingly I’m asked to require DNP3-SA in procurement.”

O*NET tasks include ‘Develop software to control electrical systems’ and field power-system work; tool list includes SCADA and PLC software. The persona that can bake security controls into system design.

15-1299.04 — Penetration Testers (Adversary emulation (Bright Outlook))

“I demonstrate frame 27 safely in a lab so the utility funds the fix before an adversary finds it.”

ONET tasks: ‘Develop and execute tests simulating known cyber threat actor techniques.’ (ONET has not yet published Knowledge domains for this newer occupation.)

25-9031.00 — Instructional Coordinators (Curriculum author)

“I turned a verified capture into objectives, exercises, and an answer key mapped to real occupations.”

O*NET tasks: ‘Interview subject-matter experts ... to develop instructional content’ and ‘ensure students are trained with technologically current ... processes’ — the persona that assembled this module.

What you practice → who does this work

These occupations do packet and detection analysis (or implement the controls) as their actual job — the skills this kit rehearses.

Skill you practice in this kit	O*NET	The real work it maps to
Read the DNP3 layers and function codes, baseline the poll/response rhythm, and differentiate a legitimate control from a spoofed frame by cross-checking IP source against the DNP3 link address — then build and revise the detection that fires on wrong-source or anomalous frames	15-1212.00	Information Security Analysts — monitor networks and analyze traffic (Wireshark/IDS) to detect intrusions
Safely emulate the command injection (frame 27) and the unseen spoofed-unsolicited-response attack to prove the risk before an adversary does	15-1299.04	Penetration Testers — develop and execute tests simulating known cyber-threat-actor techniques
Scope network segmentation, IEC 62443 zones/conduits, and an OT-firewall source allow-list around TCP/20000	15-1241.00	Computer Network Architects — design data-communication networks (‘packet analysis software’ is a named O*NET tool)

Context: who this protects

These roles operate, maintain, design, or authored the systems under analysis — not skills the learner performs here.

Occupation	O*NET	Why they are in the room
Power Distributors and Dispatchers	51-8012.00	Operate the substation from the SCADA/EMS master; the spoofed-status attack in the unseen capture is built to deceive them (loss of view). The analysis protects their picture — it does not train them.
Electrical & Electronics Repairers — Powerhouse, Substation, and Relay	49-2095.00	Build, test, and maintain the outstation relays/RTUs that are the target device — the asset this analysis defends.
Electrical Engineers	17-2071.00	Design authority: specify the RTUs/point map and require DNP3-SA in procurement so the durable fix exists.
Instructional Coordinators	25-9031.00	Authored this module from the verified capture — the author's own occupation, not a skill the learner practices.

10. References & sources

- [DNP Users Group — 'A DNP3 Protocol Primer' \(Rev A\)](#)
- [IEEE 1815-2012 — DNP3 with Secure Authentication](#)
- [CISA ICSNPP — DNP3 Zeek parser \(icsnpp-dnp3\)](#)
- [CISA ICS Advisory ICSA-13-291-01B — DNP3 Implementation Vulnerability](#)
- [E-ISAC / SANS — Analysis of the Cyber Attack on the Ukrainian Power Grid \(2016\)](#)
- [ESET — Industroyer2: Industroyer reloaded \(2022\)](#)
- [NIST SP 800-82 Rev. 3 — Guide to Operational Technology \(OT\) Security](#)
- [MITRE ATT&CK for ICS](#)
- [O*NET — Power Distributors and Dispatchers 51-8012.00](#)
- [O*NET — Information Security Analysts 15-1212.00](#)